

NARRATIVA EXPLICATIVA — MARCOS CONCEPTUALES

Context y Justificación de Preguntas Encuesta CRM

Versión: 2.0 | **Fecha:** Enero 2026 | **Clasificación:** Público

INTRODUCCIÓN

Este documento explica el "por qué" de cada pregunta en la encuesta, vinculándola a:

- Requerimientos normativos (NIST, ISO, NIS2, GDPR, DORA)
- Tendencias 2024-2025
- Mejor práctica académica/industria
- Impacto financiero directo

SECCIÓN 1: GOBERNANZA — Por Qué Es Crítico

Por Qué Importa Gobernanza

NIST CSF 2.0 (febrero 2024) introdujo "Govern" como función core porque:

1. Regulación vincul: DORA (enero 2025) + NIS2 (españa 2026) ambas requieren governance explícita
2. No basta controles técnicos; se requiere "tone at the top"
3. Junta debe conocer riesgos ciberseguridad; reportar anual mínimo
4. Precedentes breach: Change Healthcare, UnitedHealth, etc. fallaron por falta governance
5. Decisiones riesgo eran ad-hoc; no documentadas
6. Junta no tenía visibilidad
7. Valor accionista: Cyberseguridad sin governance = "black hole" presupuesto
8. Imposible justificar inversión ante CFO
9. Risk appetite indefinido = gastando en controles innecesarios

Junta debe conocer riesgos ciberseguridad; reportar anual mínimo

Precedentes breach: Change Healthcare, UnitedHealth, etc. fallaron por falta governance

Junta no tenía visibilidad

Valor accionista: Cyberseguridad sin governance = "black hole" presupuesto

Preguntas Gobernanza Justificadas

Q1.1.1 (RAS documentado): Por qué

- **DORA Art 11:** "Risk appetite must be documented"
- **NIS2:** Requiere governance structures
- **NIST Govern.RM-2:** "Board defines risk appetite"
- **Impacto:** Orgs sin RAS gastan random; no alignment junta

Q1.1.2 (Risk Tolerance umbrales): Por qué

- **Operacionalización:** RAS es estratégico; tolerancias son tácticas
- **Ejemplos reales:**
 - * "Aceptamos <5% phishing click rate; si >5% → escalar"
 - * "MTTD target <2h; si >4h → investigar SOC"
- **Benefit:** Decisions claras, sin subjetividad

Q1.1.3 (Junta oversight frecuencia): Por qué

- **Board Education Gaps:** 70% juntas no entienden cyber threats (Verizon DBIR)
- **Regulatorio:** DORA exige board oversight; audit reporta hallazgos annually
- **Precedente:** NHS breach 2024 → "Junta no sabía gravedad"

SECCIÓN 2: CUANTIFICACIÓN — Por Qué FAIR Es Necesario

Por Qué Importa Cuantificación Monetaria

Contexto:

- CFO habla €/\$; CISO habla "riesgo"
- Brecha comunicación = presupuesto bajo, decisiones pobres

Problema:

CISO: "Necesitamos EDR; es crítico"
CFO: "Cuesta €200K. Justificación?"
CISO: "Porque sí. Threat landscape."
CFO: "No convence. Presupuesto denegado."

Con FAIR:

CISO: "Ransomware ALE = €5M/año. EDR cuesta €200K, reduce ALE 40% (€2M ahorro)"
CFO: "ROI = 10:1. Aprobado en el acto."

Preguntas Cuantificación Justificadas

Q2.1.1 (FAIR adoption): Por qué

- **Standard de-facto:** 60%+ Fortune 500 usan FAIR
- **Regulatorio:** CNMV (España) recommends FAIR para sector financiero
- **ROI:** Orgs que adoptan FAIR 2-3x más efectivas control prioritization

Q2.1.2 (Top 5 riesgos cuantificados): Por qué

- **Visibility test:** Si no puedes cuantificar top 5 riesgos, no los entiendes realmente
- **Benchmark:** FAIR Institute: <30% organizations pueden

Q2.1.3 (ROI analysis for controls): Por qué

- **Budget allocation:** Control decisiones deben ser ROI-based, no "gut feel"
- **Audit evidence:** SOX, GDPR, NIS2 audits exigen documentación inversión decisions

SECCIÓN 3: THREAT MODELING — Por Qué Operacional

Por Qué Importa Threat Modeling

Contexto:

- Vulnerabilidades $\neq$ Threats
- Vulnerable $\neq$ Exploitable
- Exploitable $\neq$ Probable

Ejemplo:

Sistema tiene CVE-2025-1234 (CVSS 9.8 crítico)

Pero:

- Requiere local access (no remoto) $\rightarrow$ riesgo reducido
- Mitigado por WAF $\rightarrow$ attack path blocked
- Atacante motivation baja $\rightarrow$ probabilidad baja

Conclusión: Baja prioridad vs apariencia crítica

PASTA Framework: Valida esto mediante attack trees, PoC, probabilidades

Preguntas Threat Modeling Justificadas

Q3.1.1-3.1.3: Por qué

- **Validación Vulnerabilities:** Sin threat modeling, patching es aleatorio
- **Effectiveness:** Orgs con PASTA vs sin: 50% menos vulnerabilidades explotadas
- **Impacto:** Change Healthcare breach = "vulnerable pero explotada"; PASTA lo habría detectado

SECCIÓN 4: MÉTRICAS SOC — Por Qué MTTD/MTTR Importa

Por Qué MTTD/MTTR Son KPIs Clave

Correlación Empírica (IBM Breach Cost 2024):

MTTD reducción 200 días $\rightarrow$ 50 días $\rightarrow$ Costo breach $\downarrow$ 27%

MTTR reducción 120 horas $\rightarrow$ 24 horas $\rightarrow$ Costo breach $\downarrow$ 40%

Causación:

- Detección rápida = menos tiempo atacante lateral movement
- Respuesta rápida = menos datos exfiltrados
- Menos datos = costo breach menor

Preguntas SOC Justificadas

Q4.1.1-4.1.3: Por qué

- **Audit requirement:** DORA "incident response procedures must demonstrate <X hours"
- **Benchmarking:** 30 min - 4 horas MTTD es "good" vs España baseline 48-72h
- **Business impact:** Fast response = competitive advantage

SECCIÓN 5: VULNERABILIDADES — Por Qué SLA Crítico

Por Qué Importa Patching Velocity

Precedentes:

- Equifax breach (2017): Conocida vulnerability no parcheada durante 76 días — 143M personas
- Log4j (2021): Critical vulnerability descubierta — 10+ días antes widespread patches
- MOVEit (2023): Parches tardíos — 2.000+ organizaciones comprometidas

Requerimiento regulatorio:

- **NIS2:** "Vulnerabilities parchadas within appropriate timeframe"
- **DORA:** "Patch management SLA documentado"
- **ISO 27001:** "Timely" patches

Preguntas Vulnerabilidades Justificadas

Q5.1.2 (Patch SLA para críticos):

- **Target:** <7 días (mejor práctica); <30 días (acceptable)
- **Realidad España:** 60-90 días común — regulatorio risk

Q5.1.3 (CVSS v4.0 adoption):

- **Lanzado junio 2024:** Versión actual; v3.1 ya "legacy"
- **NIST mandate:** CVSS v3.1 deprecating 2026; v4.0 mandatory 2026

SECCIÓN 6: SUPPLY CHAIN — Por Qué Terceros Son Nuevo Perimeter

Por Qué Importa Supply Chain

Realidad:

- 50% de breaches ahora via third-party
- SolarWinds, Kaseya, CCleaner = ejemplos \$B+ impact
- **Precedente 2024:** Change Healthcare = third-party ransomware — \$2.87B

Regulatorio:

- **DORA Art 29:** "Manage ICT third-party concentration risk"
- **NIS2 GV.SC:** "Supply chain risk assessment"
- **GDPR Art 28:** "Data processor security requirements"

Preguntas Supply Chain Justificadas

Q6.1.1-6.1.3: Por qué

- **SBOM** ahora standard (EU CRA, US EO 14028)

- **Vendor audit:** No confiar vendor self-reporting; auditar anual
- **Contract leverage:** Sin requisitos ciberseguridad en contrato = sin compliance enforcement

SECCIÓN 7: AWARENESS — Por Qué ROI Comprobado

Por Qué Importa Training & ROI

Estadísticas:

- 88% de breaches causados human error / social engineering
- Phishing click rate promedio: 3-15% (antes training)
- Post-training: 4-6% (después 12 meses)

ROI:

- Training costo: €50-100/empleado/año
- Avoided breach: €10M average
- ROI: 100:1 típico

Preguntas Awareness Justificadas

Q7.1.1-7.1.4:

- **Mandatory training:** GDPR Art 32 "security awareness"
- **Phishing ROI:** Alta click rate = priority improvement
- **Reporting rate:** >20% significa employees son "security partners"

SECCIÓN 8: COMPLIANCE — Por Qué Multi-Regulatorio

Por Qué Compliance Multi-Frame

Realidad España 2026:

- GDPR (desde 2018, vigente)
- DORA (desde enero 2025, vigente sector financiero)
- NIS2 (españa ~Q1 2026, aplicable)

Overlap pero diferente:

Regulación	Scope	Requisito Core
GDPR	Privacy (datos personales)	Art 32 security measures
DORA	Financial Operational Resilience	RTO/RPO <4h críticos
NIS2	Cybersecurity (todos sectores)	Managed risk; incident reporting 24h

Orgs deben cumplir todas three simultáneamente (overlap mandates)

Preguntas Compliance Justificadas

Q8.1.1-8.1.3: Por qué

- Cada regulación score different

- **Audit findings:** Falta compliance = sanciones €10M+
- **NIST CSF 2.0:** Framework alineado con todas three

SECCIÓN 9: AUTOMATIZACIÓN — Por Qué Código>Manual

Por Qué Importa Policy-as-Code

Contexto:

- Manual policy enforcement = scalability issue
- 80% tiempo audit = validar compliance (auditable vs non-auditable)
- Policy-as-Code = automatizado → auditable siempre

Beneficio:

- Deployment rápido (minutos vs días)
- Compliance continuous (no quarterly audit)
- Drift detection (cambios no autorizados alertados inmediatamente)

Preguntas Automatización Justificadas

Q9.1.1-9.2.3:

- **Policy-as-Code:** Future-proof compliance
- **IaC:** Reproducibility, versioning, auditability
- **Chaos Engineering:** Validación RTO/RPO real (no teórico)

CONCLUSIÓN NARRATIVA

La encuesta no es "checkbox exercise". Cada pregunta mapea a:

- ✓ **Regulatorio** (GDPR, DORA, NIS2)
- ✓ **Mejor Práctica** (NIST, ISO, FAIR, PASTA)
- ✓ **Impacto Financiero** (ROI, ALE, costo breach)
- ✓ **Vulnerabilidad Real** (precedentes 2024)

Objetivo: Transformar responses cuantitativas → roadmap estratégico → inversiones justificadas.

Fin Narrativa Explicativa